

Lista de control de cumplimiento normativo

Para revisar las regulaciones y estándares de cumplimiento normativo, lee el documento sobre [controles, marcos y cumplimiento normativo](#).

_____ La Comisión Federal de Regulación de Energía, Corporación de Confiabilidad Eléctrica América del Norte (FERC-NERC)

La normativa FERC-NERC se aplica a organizaciones que trabajan con electricidad o que están involucradas con la red eléctrica de los Estados Unidos y América del Norte. Las empresas tienen la obligación de prepararse, mitigar y reportar cualquier incidente de seguridad potencial que pueda afectar negativamente a la red eléctrica. También están legalmente obligadas a cumplir con los Estándares de Confiabilidad de Protección de Infraestructura Crítica (CIP) definidos por la FERC.

Explicación: no aplica, Botium toys es una juguetería online y no trabaja con electricidad ni con la red eléctrica de EEUU. Esta normativa es solo para empresas del sector eléctrico.

X Reglamento General de Protección de Datos (RGPD)

El RGPD es una regulación general de datos de la Unión Europea (UE) que protege el procesamiento de los datos de sus residentes y su derecho a la privacidad dentro y fuera del territorio. Además, si se produce una filtración y los datos de una persona se ven comprometidos, esto debe ser informado en un plazo de 72 horas posteriores al incidente.

Explicación: Sí aplica. El caso indica que Botium Toys realiza actividades en la UE y acepta datos de usuarios. RGPD obliga a proteger los datos personales de residentes de la UE, obtener consentimiento para recolectarlos y reportar filtraciones en 72 horas. Si no cumplen, enfrentan multas altas por pérdida de datos de clientes.

X Estándares de seguridad de datos del sector de las tarjetas de pago (PCI DSS)

PCI DSS es un estándar de seguridad internacional destinado a garantizar que las organizaciones que almacenan, aceptan, procesan y transmiten información de tarjetas de crédito lo hagan en un entorno seguro.

Explicación: Sí aplica. Botium Toys acepta pagos en línea, por lo que procesa información de tarjetas de crédito. PCI DSS exige mantener un entorno seguro, cifrar datos de tarjetas y controlar el acceso para evitar fraude y pérdida de la habilitación para cobrar con tarjeta.

Ley de Transferencia y Responsabilidad de los Seguros Médicos (HIPAA)

La HIPAA es una ley federal de los Estados Unidos establecida en 1996 para proteger la información médica de las personas. Esta ley prohíbe que la información de un/a paciente sea compartida sin su consentimiento. Las organizaciones tienen la obligación legal de informar a los/las pacientes en caso de que esta información se filtre.

Explicación: no aplica, porque HIPAA regula información médica y botium toys es una juguetería.

X Controles de Sistemas y Organizaciones (SOC tipo 1, SOC tipo 2)

El SOC1 y el SOC2 se enfocan en las políticas de acceso de los usuarios y las usuarias de una organización en los diferentes niveles. Se utilizan para evaluar el cumplimiento financiero de una organización, así como los niveles de riesgo asociados. También abordan aspectos críticos como la confidencialidad, privacidad, integridad, disponibilidad, seguridad y protección general de los datos. Es importante destacar que cualquier falla en el control de estos aspectos puede resultar en posibles fraudes.

Explicación: No aplica de forma obligatoria. SOC tipo 1 y tipo 2 son auditorías voluntarias para demostrar a clientes que se controla la

seguridad, disponibilidad y privacidad de los datos. Aunque Botium Toys se beneficiaría de implementarlo a futuro, no es un requisito legal como GDPR o PCI DSS para su operación actual.